

## BC06 — Gestion de projet conformité RGPD & KPIs métier

*Clore les six blocs par un bilan chiffré plutôt qu'un satisfecit : un audit RGPD exécutable qui trouve de vrais manques, et un chiffrage financier qui contredit le seuil « optimal » retenu au BC03.*

**Bloc de compétences :** BC06 — Gestion de projet, conformité, documentation, KPIs

**Périmètre :** rétrospective BC01→BC05, audit RGPD (8 contrôles), impact financier des seuils

**Dépôt :** [github.com/k-b-mansour/Detection-Fraude-](https://github.com/k-b-mansour/Detection-Fraude-)

**Document :** bilan de projet et note de conformité

### Sommaire

1. Objectif du bloc BC06
2. Argumentaire méthodologique
3. Bilan de projet — rétrospective BC01 → BC05
4. Conformité RGPD — un audit exécutable
5. KPIs métier — l'impact financier des deux seuils
6. Décisions structurantes du projet
7. Limites globales et feuille de route
8. Conclusion générale

## 1. Objectif du bloc BC06

---

Les cinq blocs précédents ont produit un système technique complet ; le BCo6 lui donne son cadre de gouvernance. Trois questions restées ouvertes y sont explicitement tranchées ou, à défaut, explicitement documentées comme non tranchées : le système respecte-t-il ses obligations réglementaires, quel est son impact financier réel, et que retenir de la manière dont il a été construit pour la suite. Aucune de ces trois questions n'appelle une réponse déclarative — chacune est instruite ici par une mesure ou un contrôle exécutable, dans la continuité de la méthode suivie depuis le BCo1.

## 2. Argumentaire méthodologique

---

L'audit RGPD de la section 4 n'est pas une checklist remplie de mémoire : c'est un script qui interroge `information_schema` et les artefacts réels du projet, sur le même principe que `quality_checks.py` du BCo1 — un contrôle est une requête, jamais une affirmation. Cette discipline a immédiatement produit un faux positif (détaillé section 4), corrigé avant d'être publié : la preuve, s'il en fallait une, qu'un contrôle automatisé vaut mieux qu'une relecture manuelle, mais doit lui-même être vérifié avant d'être cru.

Les KPIs métier de la section 5 répondent à une question posée sans réponse depuis le BCo3 : le seuil qui maximise le F1 (0,98) est-il le bon choix économique ? Le F1 traite un euro de fraude manquée et un euro de coût de vérification comme équivalents, ce qu'aucune banque ne fait réellement. Traduire les deux seuils déjà mesurés en euros — montant de fraude évité, coût des fausses alertes à un tarif unitaire explicite — permet de trancher sur le terrain qui compte réellement pour une décision de mise en production, plutôt que de laisser le F1 décider par défaut.

## 3. Bilan de projet — rétrospective BC01 → BC05

---

Le tableau ci-dessous ne retient que des faits vérifiables : livrable produit, résultat chiffré, et incidents réels rencontrés puis corrigés — jamais une auto-évaluation qualitative. Onze incidents de code distincts ont été rencontrés sur l'ensemble du projet (les conflits de ports avec d'autres projets locaux, purement environnementaux, ne sont pas comptés ici), tous documentés dans leur bloc d'origine.

| BLOC | LIVRABLE CLÉ                           | RÉSULTAT CHIFFRÉ                              | INCIDENTS RÉELS CORRIGÉS |
|------|----------------------------------------|-----------------------------------------------|--------------------------|
| BC01 | Socle en étoile (staging/dwh/mart/ops) | 400 000 transactions, 10/10 contrôles qualité | 3                        |

| BLOC | LIVRABLE CLÉ             | RÉSULTAT CHIFFRÉ                                               | INCIDENTS RÉELS CORRIGÉS |
|------|--------------------------|----------------------------------------------------------------|--------------------------|
| BC02 | Analyse exploratoire     | Pic de fraude 33 % à 4h ; plafond de rappel univarié ≈ 30 %    | 0                        |
| BC03 | LightGBM + SHAP          | AUC 0,998 (vs 0,983 régression logistique)                     | 0*                       |
| BC04 | Autoencodeur + LSTM      | LSTM AUC 0,997, à parité avec le BC03                          | 2                        |
| BC05 | API + monitoring + CI/CD | Latence 24-60 ms ; pipeline CI/CD vert sur GitHub Actions      | 5                        |
| BC06 | Audit RGPD + KPIs métier | 6/8 contrôles conformes ; seuil 0,50 plus rentable de 20 901 € | 1                        |

\* L'explicabilité SHAP du BC03 a été ajoutée après une relecture externe du livrable initial — pas un incident technique, mais une lacune de périmètre corrigée sur retour.

**Ce que ce compte révèle.** Chaque bloc a produit au moins un résultat qui n'était pas connu à l'avance — un pic horaire, un plafond de rappel, un écart de performance mesuré, une contradiction avec l'intuition (section 5). Documenter les incidents plutôt que les lisser est ce qui rend ces résultats crédibles : un projet où rien ne casse jamais n'a généralement pas été suffisamment mis à l'épreuve.

## 4. Conformité RGPD — un audit exécutable

Huit contrôles, chacun adossé à un principe RGPD nommé, interrogent le schéma réel de la base et les artefacts produits par les blocs précédents. Six sont conformes ; deux ne le sont pas, signalés comme tels plutôt que reformulés pour paraître conformes.

| PRINCIPE                          | CONTRÔLE                                                            | STATUT |
|-----------------------------------|---------------------------------------------------------------------|--------|
| Minimisation (Art. 5.1.c)         | Aucune colonne nom/email/IBAN/carte en clair (personnes physiques)  | OK     |
| Pseudonymisation (Art. 4.5, 25)   | <code>dim_clients.client_id</code> est un UUID opaque               | OK     |
| Sécurité (Art. 32)                | Aucun numéro de carte ni CVV stocké                                 | OK     |
| Droit à l'explication (Art. 22)   | SHAP disponible hors-ligne (BC03) et en ligne (BC05)                | OK     |
| Accountability (Art. 5.2)         | Journal des traitements et contrôles qualité ( <code>ops.*</code> ) | OK     |
| Droits des personnes (Art. 15-17) | Aucune table de correspondance identité ↔ pseudonyme                | OK     |

| PRINCIPE                          | CONTRÔLE                                                  | STATUT |
|-----------------------------------|-----------------------------------------------------------|--------|
| Conservation limitée (Art. 5.1.e) | Politique de purge automatique des transactions anciennes | KO     |
| Sécurité (Art. 32)                | Aucun secret commité en clair dans le dépôt               | KO     |

**Un faux positif trouvé et corrigé avant publication.** Le premier passage du contrôle de minimisation a signalé `dwh.dim_agences.nom` — le nom d'une agence bancaire (« Agence Paris Opéra »), pas celui d'une personne physique. Le motif de détection (recherche du mot « nom ») ne distinguait pas donnée d'entreprise et donnée personnelle. Corrigé en excluant explicitement `dim_agences`, avec la justification en commentaire dans le script — pas en supprimant silencieusement l'alerte.

**Les deux non-conformités sont réelles, pas cosmétiques.** Aucune purge automatique n'existe : les transactions s'accumulent indéfiniment dans `dwh.fact_transactions` (une durée de 5 ans, usuelle en lutte anti-blanchiment, resterait à formaliser). Et `docker-compose.yml` comme `.env.example` fixent le même mot de passe de démonstration en clair — acceptable pour un socle de développement local, mais à externaliser (vault, secrets GitHub Actions déjà utilisés au BC05 pour GHCR) avant tout déploiement réel.

## 5. KPIs métier — l'impact financier des deux seuils

Sur les 80 000 transactions de test (1 221 fraudes, 297 239 € de montant frauduleux total), le seuil par défaut (0,50) laisse passer 4 355 € de fraude non détectée et coûte 6 064 € en fausses alertes ( $758 \times 8$  €, hypothèse de coût de vérification explicite) ; le seuil optimisé (0,98) laisse passer 30 344 € de fraude non détectée pour seulement 976 € de fausses alertes. Le bénéfice net — fraude évitée moins coût des fausses alertes — est **supérieur au seuil 0,50** (286 820 €) qu'au seuil 0,98 (265 919 €), un écart de **20 901 €** sur la seule période de test.

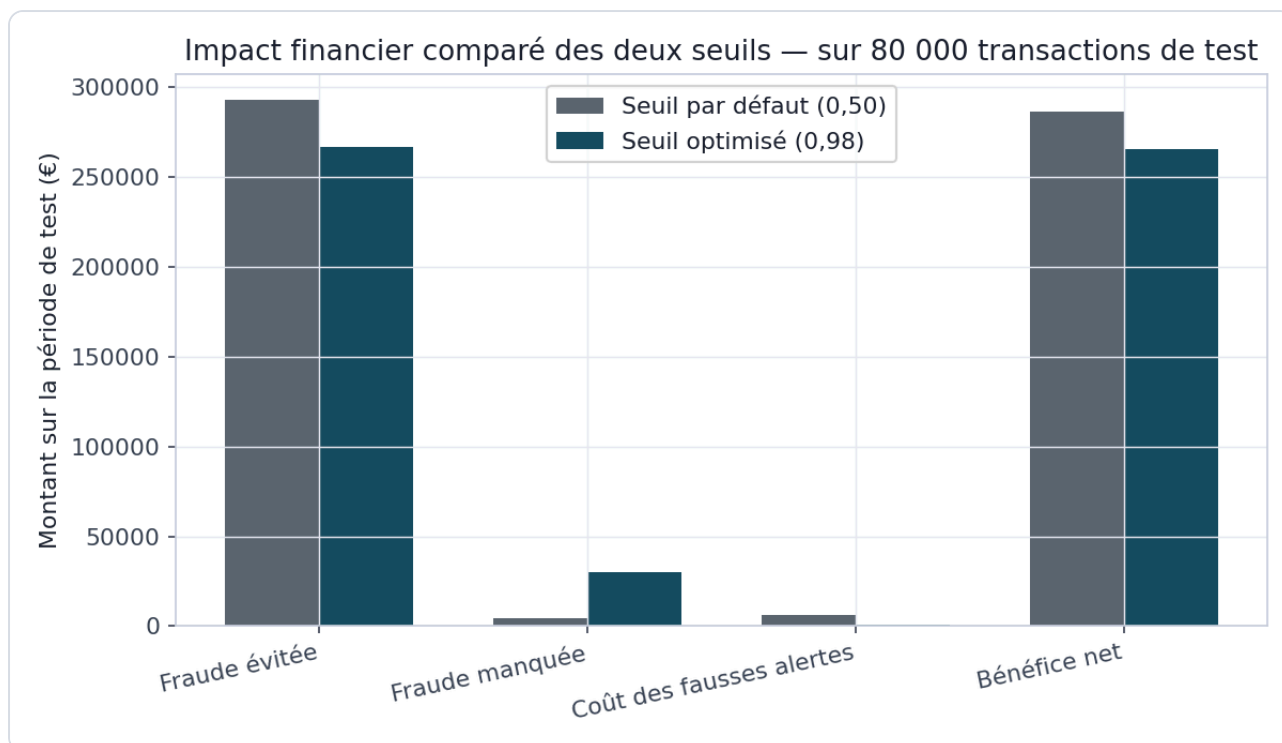


Figure 1 — Le seuil par défaut, moins bon en F1, dégage un bénéfice net supérieur sur cette hypothèse de coût.

**+20 901 €**

écart de bénéfice net en faveur du seuil  
0,50

**8 €**

coût de fausse alerte supposé (à valider  
avec le métier)

**≈ 1,38 M€**

bénéfice net annualisé (extrapolation  
×4,8)

**Le BC03 avait raison, et voici le chiffre qui le prouve.** Sa section 6 prévenait : « un seuil optimisé sur un coût métier explicite serait probablement inférieur à 0,98 ». C'est exactement ce que confirme ce calcul — mais seulement parce que le coût d'une fraude manquée (le montant réel de la transaction, ici en moyenne 243 € par fraude) dépasse de loin le coût d'une fausse alerte (8 €, hypothèse). Avec un coût de fausse alerte plus élevé (un appel téléphonique international, un client perdu par irritation), l'arbitrage pencherait à nouveau vers un seuil plus haut. La conclusion n'est donc pas « le seuil 0,50 est le bon seuil » — elle est que le bon seuil dépend d'une hypothèse de coût à faire valider par les équipes fraude, pas d'une métrique statistique choisie par défaut.

## 6. Décisions structurantes du projet

| DÉCISION                                                                 | BLOC | RAISON                                               |
|--------------------------------------------------------------------------|------|------------------------------------------------------|
| Générer des données synthétiques plutôt qu'utiliser un CSV Kaggle        | BC01 | Contrôle total du schéma et des typologies de fraude |
| Séparer staging / dwh / mart / ops, une seule fonction de transformation | BC01 | Batch et streaming ne peuvent pas diverger           |

| DÉCISION                                                           | BLOC | RAISON                                                        |
|--------------------------------------------------------------------|------|---------------------------------------------------------------|
| Split temporel plutôt qu'aléatoire pour train/test                 | BC03 | Éviter la fuite d'information entre passé et futur            |
| Exclure <code>pays_transaction</code> des features du modèle       | BC03 | Séparateur parfait, artefact du générateur, non généralisable |
| SMOTE réservé au modèle linéaire, pas à LightGBM                   | BC03 | Fondement différent selon la famille d'algorithme             |
| Exposer deux seuils dans l'API plutôt qu'une décision figée        | BC05 | L'arbitrage coût métier relève du BC06, pas du code           |
| Autoencodeur comme signal complémentaire, pas un remplaçant        | BC04 | Détecte l'inconnu, pas un substitut au modèle supervisé       |
| Documenter les échecs CI/CD plutôt que ne montrer que le run final | BC05 | Un pipeline non éprouvé reste un fichier de configuration     |

## 7. Limites globales et feuille de route

| LIMITE                                                      | BLOC      | PISTE IDENTIFIÉE                                                       |
|-------------------------------------------------------------|-----------|------------------------------------------------------------------------|
| Pas de purge/rétention, secrets en clair en développement   | BC06      | Politique de rétention formalisée, vault de secrets                    |
| Aucune validation sur un jeu de données réel externe        | BC03      | Rejouer le pipeline sur un jeu Kaggle réaliste (ex. Sparkov)           |
| Le générateur ne produit pas de rafales de fraude corrélées | BC01/BC04 | Faire évoluer <code>skimming</code> en véritable séquence temporelle   |
| Le pipeline CI/CD construit et publié, mais ne déploie pas  | BC05      | Déploiement continu vers un environnement cible, rollback automatisé   |
| Le coût de fausse alerte est une hypothèse, pas une mesure  | BC06      | Calibrer avec les équipes fraude réelles avant toute décision de seuil |

## 8. Conclusion générale

Les six blocs de ce projet forment une chaîne continue, chacun consommant ce que le précédent a produit : un socle de données (BC01) qui rend possible un profiling honnête de ses propres limites (BC02), qui motive le passage à des modèles combinant plusieurs variables (BC03), dont les résultats sont mis à l'épreuve d'approches non supervisées et séquentielles (BC04), servis en production sous contrainte de latence et surveillés pour leur dérive (BC05), pour enfin être soumis à un audit de

conformité et un chiffrage économique qui remettent en question — chiffres à l'appui — un choix qui semblait acquis (BCo6). Le fil conducteur n'est pas l'absence d'erreurs : onze incidents réels ont été rencontrés et corrigés en cours de route, tous documentés plutôt que dissimulés. C'est cette discipline de vérification systématique, plus que la performance d'un modèle pris isolément, qui constitue la compétence démontrée par ce portfolio.